

מודול 5 — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  משימות מעשיות — מודול 5: איסוף מידע (Reconnaissance)
2.  פתרונות מלאים — מודול 5: איסוף מידע (Reconnaissance)

משימות מעשיות — מודול 5: איסוף מידע (Reconnaissance)

⚠ **קרא לפני שתתחיל:** בצע איסוף מידע רק על יעד חוקי — תוכנית Bug Bounty פתוחה (עם Scope מוגדר), מכונת תרגול, או דומיין שבבעלותך. איסוף פסיבי על דומיין ציבורי מותר; **אל** תבצע פעולות אקטיביות (סריקה, ניסיונות התחברות) ללא הרשאה. ראה חומר הלימוד.

לפני שמתחילים — קרא אותי!

- **מה צריך: Kali** עם חיבור אינטרנט. רוב המשימות פסיביות (דפדפן + כלים). כל משימה בנויה כך: **מטרה** → **צעדים** → ☒ **קריטריון הצלחה** — פשוט עקוב.
- **איך עובדים:** קרא קודם את ה-`README.md`. המשימות כאן כבר **ישירות ומפורטות** (הפקודות/האתרים בפנים). אם משימה מפנה ל-`TARGET.com` — החלף ביעד החוקי שלך.
- **נתקעת?** נסה, קרא שוב את הסעיף ב-`README`, ואז הצץ ב-`solutions.md` — יש שם הדגמה ותשובה לכל משימה.
- **טיפ:** שמור כל פיסת מידע שאתה מוצא — היא תזין את שלב הסריקה (מודול 6) ואת האתגר המסכם.

מקרא רמות: ● בסיסי • ● בינוני • ● אתגר

יעד לדוגמה במשימות: נשתמש בדומיין ציבורי לתרגול פסיבי בלבד. אם אתה בתוכנית Bug Bounty — השתמש ביעד שבתוך ה-Scope.

משימה 1 — קריאת Scope

מטרה: להרגיל לקרוא גבולות הרשאה לפני כל פעולה.

צעדים: 1. היכנס ל-[HackerOne Directory](#) או [Bugcrowd](#). 2. בחר תוכנית ציבורית אחת ופתח את עמוד ה-Scope. 3. רשום: 2 נכסים **In-Scope** ו-2 נכסים **Out-of-Scope**.

☒ **קריטריון הצלחה:** הבחנת נכון בין נכסים מותרים לאסורים.

? **שאלה:** מה עלול לקרות אם תתקוף נכס Out-of-Scope?

משימה 2 — זיהוי טכנולוגיות אתר

מטרה: למפות את ה-Tech Stack של יעד (פסיבי).

צעדים: 1. פתח את builtwith.com והזן דומיין יעד. 2. התקן את התוסף [Wappalizer](https://wappalizer.com) בדפדפן ובקר באתר היעד. 3. רשום: שרת ה-Web, שפת התכנות/Framework, ו-CMS (אם קיים).

✔ **קריטריון הצלחה:** זיהית לפחות 3 טכנולוגיות ואת גרסת שרת ה-Web (אם נחשפת).

? **שאלה:** מדוע גרסת שרת ישנה היא ממצא חשוב?

משימה 3 — Google Dorking

מטרה: לתרגל אופרטורי חיפוש ממוקדים.

הרץ בגוגל את השאילתות הבאות (החלף TARGET.com ביעד):

```
site:TARGET.com
site:TARGET.com filetype:pdf
site:TARGET.com inurl:login
site:TARGET.com intitle:"index of"
```

✔ **קריטריון הצלחה:** לפחות שאילתה אחת החזירה תוצאה מעניינת (קובץ, עמוד ניהול, ספריה חשופה).

מיני-אתגר: גלוש ל-Google Hacking Database ומצא Dork אחד שלא הכרת.

משימה 4 — גילוי תת-דומיינים

מטרה: להרחיב את משטח התקיפה עם Sublist3r.

צעדים (ב-Kali):

```
sudo apt install sublist3r -y
sublist3r -d TARGET.com
```

אם ההתקנה נכשלת — התקן ידנית:

```
git clone https://github.com/about3la/Sublist3r.git
cd Sublist3r
pip install -r requirements.txt
python3 sublist3r.py -d TARGET.com
```

✓ **קריטריון הצלחה:** קיבלת רשימת תת-דומיינים. סמן את אלה שנראים כמו סביבות פיתוח/בדיקה (dev , test , staging).

? **שאלה:** מדוע תת-דומיין בשם dev מעניין יותר לתוקף?

משימה 5 — OSINT על מיילים

מטרה: לזהות את תבנית המייל של ארגון.

צעדים: 1. פתח את hunter.io והזן דומיין של ארגון. 2. זהה את **תבנית המייל** (למשל {first}@company.com). 3. בדוק מייל אחד לתקינות ב-email-checker.net או דומה. 4. בדוק דומיין/מייל ב-[HaveIBeenPwned](https://HaveIBeenPwned.com).

💡 **ללא הרשמה:** hunter.io דורש חשבון חינמי ומגביל תוצאות. חלופה מ-Kali בלי הרשמה — `theHarvester -d <domain> -b bing,duckduckgo,crtsh` (ראה §5.10 README) אוסף מיילים ושמות ישירות.

✓ **קריטריון הצלחה:** זיהית את תבנית המייל של הארגון.

⚠️ אין לשלוח מיילים, לנסות התחברות או לבצע פעולה כלשהי עם המידע — זהו תרגול OSINT פסיבי בלבד.

משימה 6 — Burp Suite: לכידת בקשה ראשונה

מטרה: להקים את Burp כ-Proxy ולראות תעבורה.

צעדים: 1. פתח **Burp Suite** ב-Kali → Temporary Project → Use Burp defaults → Start Burp. 2. הגדר את HTTP Proxy , 127.0.0.1 Firefox: Settings → Network Settings → Manual proxy , פורט 8080. 3. ב-Burp, `Intercept is on` → Proxy → Intercept. 4. גלוש לאתר תרגול (למשל <http://testphp.vulnweb.com>) וצפה בבקשה שנתפסה.

✓ **קריטריון הצלחה:** תפסת בקשת HTTP אחת ואתה רואה את ה-Headers שלה ב-Burp.

אתגר מסכם — “תיק מודיעין על יעד”

בחר יעד **חוקי** אחד (מכונת תרגול או תוכנית Bug Bounty בתוך Scope), והפק דוח Recon פסיבי קצר הכולל:

1. **Scope** — הנכסים שבתוך ובחוץ.
2. **Tech Stack** — שרת, שפה, CMS, Framework (מ-builtwith/Wappalyzer).
3. **תת-דומיינים** — רשימה מ-Sublist3r, עם סימון הפגיעים-לכאורה.
4. **תבנית מייל** — אם רלוונטי (hunter.io).
5. **ממצאי 2** — **Google Dorking** תוצאות מעניינות.
6. **סיכום** — פסקה: “משטח התקיפה הבולט של היעד הוא _____, וההמלצה לשלב הסריקה הבא היא _____.”
זהו הבסיס למודול 6 — שם נתחיל לסרוק **אקטיבית** את מה שמיפינו.

רשימת בקרה — לפני מעבר למודול 6

- ☐ אני יודע לקרוא ולכבד Scope
- ☐ אני יודע לזהות את ה-Tech Stack של יעד
- ☐ אני שולט ב-3 אופרטורים של Google Dorking לפחות
- ☐ הרצתי Sublist3r וקיבלתי תת-דומיינים
- ☐ זיהיתי תבנית מייל עם hunter.io
- ☐ הקמתי את Burp Suite ותפסתי בקשה

פתרונות מלאים: [solutions.md](#)

פתרונות מלאים — מודול 5: איסוף מידע (Reconnaissance)

נסה לבד ב- [missions.md](#) קודם. חלק מהתרגילים הם חקירה חופשית — כאן ההנחיות והתשובות לדוגמה.

משימה 1 — קריאת Scope

היכנס ל-HackerOne או Bugcrowd, פתח תוכנית ציבורית, וגלול לסעיף **In-Scope** / **Scope / Targets**. לדוגמה: `*.example.com`, אפליקציית המובייל הרשמית. **Out-of-Scope** - לדוגמה: `blog.example.com` (WordPress מנוהל), נכסים של צד ג', מתקפות DoS.

מה עלול לקרות אם תתקוף Out-of-Scope? אין הרשאה חוקית → זו עבירה פלילית / הפרת תנאי התוכנית, ללא תשלום ובאחריותך המשפטית.

משימה 2 — זיהוי טכנולוגיות אתר

1. `builtwith.com` → קרא → הוץ דומיין Framework / Server / CMS / Analytics
2. בדפדפן ובקר באתר Wappalyzer התקן

דוגמת פלט: CDN: WordPress 6.1 ; CMS: React ; Framework: nginx ; Web Server: Cloudflare.

מדוע גרסה ישנה חשובה? לגרסאות ישנות יש לרוב **חולשות ידועות (CVE)** עם Exploits מוכנים — נקודת כניסה מהירה בשלב הניצול (מודול 7).

משימה 3 — Google Dorking

<code>site:TARGET.com</code>	→ כל הדפים המאונדקסים
<code>site:TARGET.com filetype:pdf</code>	→ (לעיתים רגילים) מסמכי PDF
<code>site:TARGET.com inurl:login</code>	→ עמודי התחברות
<code>site:TARGET.com intitle:"index of"</code>	→ ספריות חשופות

תוצאה מעניינת = קובץ פנימי, עמוד ניהול, או ספריית קבצים פתוחה. ל-Dorks נוספים: **Google Hacking Database**.

משימה 4 — גילוי תת-דומיינים

```
sudo apt install sublist3r -y
sublist3r -d TARGET.com
# חלופה ידנית:
git clone https://github.com/aboul3la/Sublist3r.git
cd Sublist3r && pip install -r requirements.txt
python3 sublist3r.py -d TARGET.com
```

סמן תת-דומיינים כמו `.admin.` , `.test.` , `.staging.` , `.dev.`

מדוע `.dev` מעניין? סביבות פיתוח/בדיקה לרוב מאובטחות פחות (סיסמאות ברירת מחדל, דיבוג פתוח, גרסאות ישנות) — יעד קל יותר.

משימה 5 — OSINT על מיילים

1. `hunter.io` → למשל `{first}.{last}@company.com` הזן דומיין → זהה את תבנית המייל, למשל
2. `email-checker.net` → אמת מייל בודד
3. `haveibeenpwned.com` → בדוק אם הדומיין/מייל הופיע בדלף

תבנית המייל מאפשרת לנחש מיילים של עובדים נוספים (לצורך פשינג/Password Spraying — בתוך Scope בלבד).

⚠ אין לשלוח מיילים או לנסות התחברות — זהו OSINT פסיבי בלבד.

משימה 6 — Burp Suite: לכידת בקשה

1. Burp → Temporary Project → Use Burp defaults → Start Burp
2. Firefox → Settings → Network Settings → Manual proxy → `127.0.0.1:8080`
3. Burp → Proxy → Intercept → "Intercept is on"
4. גלוש ל `http://testphp.vulnweb.com`
5. Headers-ואת ה-GET-הבקשה נתפסה; קרא את שורת ה- Burp-חזור ל

תראה את מתודת ה-HTTP, הנת"ב, ה-Host, ה-User-Agent, ועוגיות (Cookies). זהו הבסיס לתקיפות Web (מודול 9).

אתגר מסכם — מבנה "תיק מודיעין" לדוגמה

תיק מודיעין – TARGET.com

1. Scope

In: *.target.com, app.target.com

Out: blog.target.com, third-party.com

2. Tech Stack (builtwith / Wappalyzer)

Server: nginx 1.18 | Framework: Laravel | CMS: – | CDN: Cloudflare

3. תת-דומינים (Sublist3r)

www, mail, dev*, staging*, vpn (* = פגוע = פוטנציאל)

4. תבנית מייל (hunter.io)

{first}.{last}@target.com

5. Google Dorking

- site:target.com filetype:pdf → מדריך פנימי חשוב

- inurl:admin → פאנל ניהול

6. סיכום

(סביבת פיתוח חשופה) dev.target.com משטח התקיפה הבולט: תת-הדומיין

(מודול 6) vpn-ול dev-ממוקדת ל nmap המלצה לשלב הבא: סריקת

עברת? יש לך תמונת מודיעין מלאה. המשך למודול 6 — סריקה ומיפוי, שם נסרוק **אקטיבית** את מה שמיפינו.